

NEXORA

Documentation API — Authentication

Création de compte & Connexion

Destinataire : partenaires intégrateurs

Version 1.0 • 25 mai 2026

Confidentiel — Usage technique uniquement

1. Introduction

Ce document décrit les deux endpoints d'authentification exposés par l'API NEXORA pour permettre à un partenaire intégrateur de :

- Créer un compte utilisateur sur la plateforme (PME, Partenaire ou Expert).
- Authentifier un utilisateur existant et récupérer un jeton JWT pour les appels suivants.

1.1 URL de base

Toutes les routes décrites dans ce document sont préfixées par l'URL de base de l'environnement cible :

```
# Environnement de développement
https://nexora-backend.dev-teams.me
# Environnement de production (à confirmer avec l'équipe NEXORA)
https://api.nexorapme.com
```

1.2 Format de réponse

Toutes les réponses (succès et erreurs) suivent le même format JSON enveloppé :

```
{
  "status": "SUCCESS" | "FAILURE" | "ERROR",
  "message": "Libellé court",
  "description": "Description détaillée pour affichage utilisateur",
  "data": { ... } | null
}
```

- status = "SUCCESS" → opération réussie (code HTTP 2xx)
- status = "FAILURE" → erreur métier / validation (code HTTP 4xx)
- status = "ERROR" → erreur serveur inattendue (code HTTP 5xx)

1.3 Content-Type

Toutes les requêtes POST/PUT doivent inclure le header suivant :

```
Content-Type: application/json
```

2. Création de compte

2.1 Endpoint

POST /api/v1/auth/register

Crée un nouvel utilisateur dans le système. Selon le rôle choisi, un profil métier associé (PME ou Partenaire) est automatiquement créé.

Authentification requise

Non — endpoint public.

Headers requis

Content-Type: application/json

Paramètres en entrée (body JSON)

Paramètre	Type	Requis	Description
email	string	Oui	Adresse email valide de l'utilisateur. Doit être unique sur la plateforme.
mot_de_passe	string	Oui	Mot de passe en clair (minimum 6 caractères). Sera hashé en base avec bcrypt.
role	enum	Oui	Rôle de l'utilisateur. Valeurs autorisées : "pme", "partenaire", "expert".
in_africa	boolean	Non	Indique si la PME/Partenaire est basé(e) en Afrique. Défaut : true. Sert à déterminer le catalogue d'abonnements proposé.

Exemple de requête

```
POST /api/v1/auth/register HTTP/1.1
Host: api.nexorapme.com
Content-Type: application/json

{
  "email": "contact@ma-pme.com",
  "mot_de_passe": "MonMotDePasseFort!2025",
  "role": "pme",
  "in_africa": true
}
```

Réponse de succès (201 Created)

```
{
  "status": "SUCCESS",
  "message": "Compte créé avec succès.",
  "description": "Compte créé avec succès.",
  "data": {
    "id": "f5e8a3b1-7c4d-4f29-9e1a-2b3c4d5e6f7a",
    "email": "contact@ma-pme.com",
    "role": "pme",
    "in_africa": true,
    "profil_id": "a1b2c3d4-e5f6-7890-abcd-ef1234567890"
  }
}
```

Réponses possibles

Code HTTP	Status / Message	Scénario / Action recommandée
201	SUCCESS	Compte créé avec succès. Le profil PME ou Partenaire associé est automatiquement initialisé.
400	FAILURE — validation	Données invalides (email mal formaté, mot de passe < 6 caractères, rôle non reconnu, champ requis manquant...). Le champ "description" précise l'erreur exacte.
409	FAILURE — duplicate	L'email fourni est déjà associé à un compte existant. Demander à l'utilisateur d'utiliser un autre email ou de se connecter.
500	ERROR — serveur	Erreur serveur inattendue (base de données indisponible, etc.). Réessayer après quelques secondes ; si le problème persiste, contacter le support NEXORA.

Exemple d'erreur 409 (email existant)

```
{
  "status": "FAILURE",
  "message": "Cet email est déjà utilisé.",
  "description": "Cet email est déjà utilisé.",
  "data": null
}
```

3. Connexion

3.1 Endpoint

POST /api/v1/auth/login

Authentifie un utilisateur existant et retourne un jeton JWT à utiliser dans les appels API suivants.

Authentification requise

Non — endpoint public.

Headers requis

Content-Type: application/json

Paramètres en entrée (body JSON)

Paramètre	Type	Requis	Description
email	string	Oui	Adresse email du compte à connecter.
mot_de_passe	string	Non	Mot de passe de l'utilisateur. Au choix avec "password" (l'un des deux est obligatoire).
password	string	Non	Alias de "mot_de_passe" (pour compatibilité avec les frameworks anglophones).

Exemple de requête

```
POST /api/v1/auth/login HTTP/1.1
Host: api.nexorapme.com
Content-Type: application/json

{
  "email": "contact@ma-pme.com",
  "mot_de_passe": "MonMotDePasseFort!2025"
}
```

Réponse de succès (200 OK)

```
{
  "status": "SUCCESS",
  "message": "Connexion réussie.",
  "description": "Connexion réussie.",
  "data": {
    "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
    "user": {
      "id": "f5e8a3b1-7c4d-4f29-9e1a-2b3c4d5e6f7a",
      "email": "contact@ma-pme.com",
      "role": "pme",
      "is_active": true
    }
  }
}
```

Réponses possibles

Code HTTP	Status / Message	Scénario / Action recommandée
-----------	------------------	-------------------------------

Code HTTP	Status / Message	Scénario / Action recommandée
200	SUCCESS	Authentification réussie. Le token JWT est valide pendant 24 heures par défaut.
400	FAILURE — validation	Champs manquants ou email mal formaté.
401	FAILURE — auth	Email inconnu OU mot de passe incorrect. Le message est identique dans les deux cas (anti-énumération).
403	FAILURE — compte désactivé	Le compte existe et le mot de passe est bon, mais il a été désactivé par un administrateur. Contacter le support NEXORA.
500	ERROR — serveur	Erreur serveur inattendue. Réessayer plus tard.

Exemple d'erreur 401 (identifiants invalides)

```
{
  "status": "FAILURE",
  "message": "Email ou mot de passe incorrect.",
  "description": "Email ou mot de passe incorrect.",
  "data": null
}
```

4. Utilisation du jeton JWT

Une fois le token récupéré via `/auth/login`, il doit être inclus dans chaque appel à une route protégée via le header `Authorization` au format `Bearer`.

4.1 Format du header

```
Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...
```

4.2 Durée de vie

Le token est valide pendant 24 heures par défaut (paramétrable côté serveur via `JWT_EXPIRES_IN`). Au-delà, toutes les requêtes répondront 401 avec le message "Token invalide ou expiré." — l'application cliente doit alors réauthentifier l'utilisateur via `/auth/login`.

4.3 Exemple d'appel authentifié

```
GET /api/v1/auth/me HTTP/1.1
Host: api.nexorapme.com
Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...

# Réponse 200 OK
{
  "status": "SUCCESS",
  "data": {
    "id": "f5e8a3b1-7c4d-4f29-9e1a-2b3c4d5e6f7a",
    "email": "contact@ma-pme.com",
    "role": "pme"
  }
}
```

4.4 Erreurs liées au token

Code HTTP	Status / Message	Scénario / Action recommandée
401	Token manquant	Le header <code>Authorization</code> est absent. Inclure <code>"Authorization: Bearer <token>"</code> .
401	Token invalide / expiré	Token mal formé, signature invalide ou expiré (> 24h). Demander à l'utilisateur de se reconnecter via <code>/auth/login</code> .
403	Rôle insuffisant	L'utilisateur est authentifié mais son rôle n'autorise pas cette action (ex : un compte PME tentant d'accéder à un endpoint admin).

5. Récapitulatif des codes HTTP

Code HTTP	Status / Message	Scénario / Action recommandée
200	SUCCESS	Requête traitée avec succès (lecture / connexion).
201	SUCCESS — Created	Ressource créée (inscription).
400	FAILURE	Données invalides : validation joi a échoué. Voir "description" pour le détail.
401	FAILURE — Unauthorized	Authentification requise OU identifiants/token invalide.
403	FAILURE — Forbidden	Authentifié mais accès refusé (compte désactivé ou rôle insuffisant).
409	FAILURE — Conflict	Conflit avec une ressource existante (email déjà utilisé).
500	ERROR	Erreur serveur inattendue. Réessayer ; signaler au support si persistant.

5.1 Bonnes pratiques côté partenaire intégrateur

- Stocker le token JWT dans un emplacement sécurisé (HttpOnly cookie côté backend, sessionStorage / localStorage côté SPA selon votre stratégie).
- Implémenter une logique de refresh : sur réception d'un 401, rediriger vers la page de login.
- Ne JAMAIS exposer le mot de passe dans les logs, traces ou URLs.
- En production, utiliser exclusivement HTTPS pour tous les appels.